



SQLi Login



Bối cảnh (Context)

Rút kinh nghiệm từ bài học Login Bypass, đội Dev đã bật cơ chế lọc (WAF) để loại bỏ các ký tự dấu cách (space) và một số từ khóa như `OR`, `AND`. Hơn thế nữa, họ đã ngăn cấm người dùng tự động đăng nhập dù câu lệnh SQL có trả về TRUE đi chăng nữa.

Nhưng có một điểm yếu: khi câu truy vấn SQL bị lỗi, máy chủ không trả về thông báo chung chung mà lại ném thẳng toàn bộ nội dung lỗi cơ sở dữ liệu chi tiết ra màn hình.



Mục tiêu (Objective)

- **Nhiệm vụ:** Lấy được thông tin từ cơ sở dữ liệu (ví dụ version, tên bảng, Flag) dựa trên các thông báo lỗi.
- **Vấn đề / Lỗi hổng:** **Error-based SQL Injection** kết hợp **WAF Bypass**. Dữ liệu lấy ra không hiện trực tiếp trên giao diện mà được ép phải hiển thị thông qua các lỗi cố ý sinh ra bằng các hàm như `EXTRACTVALUE()` hoặc `UPDATEXML()` (đối với MySQL).
- **Flag:** Trích xuất bảng chứa Flag bằng thông báo lỗi.



Gợi ý (Hints)

- Sử dụng `/**/` hoặc ký tự tab để thay thế khoảng trắng bị filter.
- Một payload mẫu Error-based: `1' AND EXTRACTVALUE(1, CONCAT(0x7e, (SELECT @@version)))-`

```
--
```